mSEC-AM Audit Summary

OpenMRS Android Client - v3.1.1

Audit Date: 17 Apr 2026
Auditor: Juan José López Jiménez
Classification: Confidential / Internal Use

Table of Contents

1. App information
2. Actors
3. Scope and limitations
4. Evidence criteria
5. Audit summary
    5.1 Key takeaways (Top findings)
    5.2 Positive controls observed
    5.3 Risk scoring approach
    5.4 Risk triage (prioritized)
6. Main deficiencies
7. Recommendations
8. Visual Analytics
9. Management Action Plan (MAP)
Appendix A - Traceability index (non-exhaustive)
Appendix B - Positive controls verification (workbook traceability)

1. App information

Name	OpenMRS
Developer	Openmrs.org
Category	Mobile Health (mHealth) / EMR Client
Supported platforms	Android (SDK 19-33+)
Version	3.1.2
Last update	31/03/2026
Compatible idioms	English
Source	Open source
License	MPL-2.0
Main language	Java + Kotlin + XML + Groovy

2. Actors

Auditor	Juan José López Jiménez
Requirement Engineering team	Carlos M. Mejía-Granda José L Fernández-Alemán Juan Manuel Carrillo-de-Gea Joaquín Nicolás Juan José López Jiménez
Engineering Group (EN)	Carlos M. Mejía-Granda José L Fernández-Alemán Juan Manuel Carrillo-de-Gea Joaquín Nicolás Juan José López Jiménez

3. Scope and limitations

This Audit Summary consolidates the compliance determinations recorded in the audit workbook. The results reflect the assessed application version and the workbook-defined scope. Controls not evidenced as implemented in the workbook are reported as non-compliant for summary purposes.

4. Evidence criteria

- Compliant: the workbook provides sufficient evidence that the control is implemented and effective for the assessed scope.
- Non-compliant: the workbook indicates the control is missing, insufficient, or not evidenced.
- Not applicable: the control is recorded as out of scope or not relevant for the assessed context.

5. Audit summary

The audit was carried out using the mSEC-AM (mobile SECurity Audit Method).

Overall, 469 requirements were assessed. 404 were applicable controls and 65 were recorded as not applicable. Of the applicable controls, 31 were compliant and 373 were non-compliant, resulting in an overall compliance rate of 7.67% (applicable controls only).

This report summarizes the dominant weakness patterns evidenced by non-compliant requirements and proposes actionable remediations suitable for mHealth/EMR environments handling sensitive health information.

5.1 Key takeaways (Top findings)

Key takeaways (Top findings)

- Hardcoded credentials / embedded secrets — High severity; 65 related non-compliant control(s) in the workbook.
- Authorization / RBAC / least privilege gaps — High severity; 50 related non-compliant control(s) in the workbook.
- Insecure local storage / key management gaps — High severity; 49 related non-compliant control(s) in the workbook.
- Weak authentication lifecycle / brute-force protections — High severity; 44 related non-compliant control(s) in the workbook.
- Supply chain governance & outdated components — High severity; 20 related non-compliant control(s) in the workbook.
- Transport security / certificate validation weaknesses — High severity; 20 related non-compliant control(s) in the workbook.
- Input validation & injection weaknesses (XSS/SQLi/command/log injection) — High severity; 10 related non-compliant control(s) in the workbook.

5.2 Positive controls observed

All statements below are derived exclusively from controls recorded as Compliant in the audit workbook and include supporting signals (flags and/or evidence). Verification traceability is provided in Appendix B.

- The application applications not change the SSL verification method that can allow self-signed certificates. Self-signed certificates or a local Certificate Authority (CA) be used during development to keep with good SSL practices.
- The application remove all code that seems to accept every SSL/TLS certificate, e.g., org.apache.http.conn.ssl.AllowAllHostnameVerifier, SSLSocketFactory.ALLOW_ALL_HOSTNAME_VERIFIER, post-development cycle for secure certificate validation.
- The application be free of adware and known malware (via virus-checking against some established library of viruses), and prevents the execution of malicious code, as well as disallowing the uploading of malicious or dangerous-looking scripts or files.
- The application request the READ_SMS permission only when absolutely necessary, minimize its usage, and securely handle SMS data to prevent misuse or exploitation by malicious third parties.
- The application encrypt passwords during transmission to ensure that no passwords are sent in clear text over the network.

- The application prioritize secure and authenticated communication methods, such as Firebase Cloud Messaging (FCM) or encrypted IP-based networking protocols, instead of relying on SMS for app-server interactions.
- The application assume that the network layer is unsecure and susceptible to eavesdropping. Implement end-to-end encryption and other secure communication practices to safeguard sensitive data transmitted over the network.

5.3 Risk scoring approach

Severity and likelihood ratings in this report follow a qualitative rubric grounded in the audit workbook:
- Severity reflects potential impact on confidentiality, integrity, and availability of health information, including regulatory exposure.
- Likelihood is derived from workbook prevalence: the count of non-compliant controls mapped to a weakness pattern as a proxy for exposure.
Likelihood mapping: High (>=50), Medium-High (20-49), Medium (10-19), Low-Medium (<10).

5.4 Risk triage (prioritized)

Weakness pattern	Severity (rubric)	Impact	Likelihood (workbook prevalence)	Workbook basis	Recommended owner	Target timeline
Hardcoded credentials / embedded secrets	High	The weakness pattern can compromise confidentiality/integrity/availability of health information and increase regulatory exposure.	High	65 mapped non-compliant control(s) in the workbook.	Mobile Engineering / Security Engineering	0–90 days
Authorization / RBAC / least privilege gaps	High	The weakness pattern can compromise confidentiality/integrity/availability of health information and increase regulatory exposure.	High	50 mapped non-compliant control(s) in the workbook.	Mobile Engineering / Governance	0–90 days

Insecure local storage / key managemen t gaps	High	The weakness pattern can compromise confidentiali ty/integrity/ availability of health information and increase regulatory exposure.	Medium–High	49 mapped non-compliant control(s) in the workbook.	Mobile Engineering	0–90 days
Weak authenticati on lifecycle / brute-force protections	High	The weakness pattern can compromise confidentiali ty/integrity/ availability of health information and increase regulatory exposure.	Medium–High	44 mapped non-compliant control(s) in the workbook.	Mobile Engineering	0–90 days
Supply chain governance & outdated components	High	The weakness pattern can compromise confidentiali ty/integrity/ availability of health information and increase regulatory exposure.	Medium–High	20 mapped non-compliant control(s) in the workbook.	DevOps / Security Engineering	0–90 days
Transport security / certificate validation weaknesses	High	The weakness pattern can compromise confidentiali ty/integrity/ availability of health information and increase regulatory exposure.	Medium–High	20 mapped non-compliant control(s) in the workbook.	Mobile Engineering / DevOps	0–90 days
Input validation &	High	The weakness	Medium	10 mapped non-	Mobile Engineering	0–90 days

injection weaknesses (XSS/SQLi/command/log injection)		pattern can compromise confidentiality/integrity/availability of health information and increase regulatory exposure.		compliant control(s) in the workbook.		
Audit logging completeness / retention / alerting gaps	Medium	The weakness pattern can compromise confidentiality/integrity/availability of health information and increase regulatory exposure.	Medium–High	47 mapped non-compliant control(s) in the workbook.	Governance / DevOps	0–180 days
Tampering / reverse engineering protections missing	Medium	The weakness pattern can compromise confidentiality/integrity/availability of health information and increase regulatory exposure.	Medium	16 mapped non-compliant control(s) in the workbook.	Mobile Engineering	0–180 days
Privacy notice / consent / governance gaps	Medium	The weakness pattern can compromise confidentiality/integrity/availability of health information and increase regulatory exposure.	Low–Medium	6 mapped non-compliant control(s) in the workbook.	Governance / Product	0–180 days

6. Main deficiencies

The following deficiencies are synthesized as common weakness patterns based on non-compliant requirements. They are not grouped by category; instead they represent cross-cutting gaps evidenced in the audit workbook.

Hardcoded credentials / embedded secrets (High)

Workbook basis: 65 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering / Security Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ICU-001, SECM-CAT-ICU-002, SECM-CAT-ICU-003, SECM-CAT-ICU-004.

- Evidence anchor (from workbook description): The mobile application should not contain hardcoded details of external resources, credentials, or API keys to prevent unauthorized access and secure the app from vulnerabilities.
- Evidence anchor (from workbook description): Applications shall not store passwords or secrets in the application binary, nor inhibit backend integration by using generic shared secrets.

Authorization / RBAC / least privilege gaps (High)

Workbook basis: 50 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering / Governance

Traceability (examples, non-exhaustive): SECM-CAT-ISU-027, SECM-CAT-ISU-032, SECM-CAT-IAA-005, SECM-CAT-IAA-006.

- Evidence anchor (from workbook description): The user-facing components of the application must be logically or physically separated from the data storage and management interfaces and security functions. And security-related functionality is to be isolated; you ca...

- Evidence anchor (from workbook description): Modify and maintain privileges for software libraries must be controlled within application owners.

Insecure local storage / key management gaps (High)

Workbook basis: 49 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-019, SECM-CAT-ISU-036, SECM-CAT-IAA-040, SECM-CAT-IAA-112.

- Evidence anchor (from workbook description): The app should not store any biometric data or private keys on the client device, thus would store and process sensitive data only on the server.
- Evidence anchor (from workbook description): The application should be built to run in untrusted environments and should only retrieve the absolute minimum amount of information needed to function—limiting the potential for data leakage or corruption.

Weak authentication lifecycle / brute-force protections (High)

Workbook basis: 44 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-011, SECM-CAT-IAA-003, SECM-CAT-IAA-008, SECM-CAT-IAA-011.

- Evidence anchor (from workbook description): The application must continue with strong access control, and local integrity checks applied to determine if the code has been modified without permission.
- Evidence anchor (from workbook description): The application must prevent non-privileged users from executing privileged functions, including disabling, circumventing, or altering implemented security safeguards or countermeasures.

Supply chain governance & outdated components (High)

Workbook basis: 20 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: DevOps / Security Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-008, SECM-CAT-ISU-009, SECM-CAT-ISU-013, SECM-CAT-ISU-022.

- Evidence anchor (from workbook description): Ensure that any resources used outside of standard app-store mechanisms are signed and also verify the signature before accepting updates.
- Evidence anchor (from workbook description): The application shall be subject to periodic security assessments including code reviews, penetration tests, and cryptographic vulnerabilities assessments according to the results of which security holes must be remedied...

Transport security / certificate validation weaknesses (High)

Workbook basis: 20 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering / DevOps

Traceability (examples, non-exhaustive): SECM-CAT-ISU-003, SECM-CAT-ISU-004, SECM-CAT-ISU-007, SECM-CAT-ISU-010.

- Evidence anchor (from workbook description): The application shall not contain any unmanaged and unsigned mobile code.
- Evidence anchor (from workbook description): The application shall not contain any mobile code that is uncategorized or lacks a digital signature.

Input validation & injection weaknesses (XSS/SQLi/command/log injection) (High)

Workbook basis: 10 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-037, SECM-CAT-IOV-001, SECM-CAT-IOV-004, SECM-CAT-IOV-011.

- Evidence anchor (from workbook description): The application needs to implement protections against log injection by clients so that event histories in the backend system cannot be corrupted or forged.
- Evidence anchor (from workbook description): The application must implement comprehensive input validation mechanisms to safeguard against vulnerabilities and insecure deserialization. All input from external sources, including files, network communications, and in...

Audit logging completeness / retention / alerting gaps (Medium)

Workbook basis: 47 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Governance / DevOps

Traceability (examples, non-exhaustive): SECM-CAT-IAA-004, SECM-CAT-IAA-010, SECM-CAT-IAA-014, SECM-CAT-IAA-019.

- Evidence anchor (from workbook description): The application must terminate all existing user sessions immediately upon account deletion to prevent unauthorized access to application resources.
- Evidence anchor (from workbook description): The application must validate log-on information only after all input data has been completed and must not indicate which specific part of the input is correct or incorrect in case of an error.

Tampering / reverse engineering protections missing (Medium)

Workbook basis: 16 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-006, SECM-CAT-ISU-012, SECM-CAT-ISU-017, SECM-CAT-ISU-026.

- Evidence anchor (from workbook description): The application must incorporate look designs to distinguish unauthorized code changes and meddling with the binary.
- Evidence anchor (from workbook description): The anti-tampering techniques to prevent code alterations and runtime inspections of your application must be implemented by the application.

Privacy notice / consent / governance gaps (Medium)

Workbook basis: 6 related non-compliant control(s) mapped to this pattern.

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook indicates the related controls are missing, insufficient, or not evidenced for the assessed scope.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Governance / Product

Traceability (examples, non-exhaustive): SECM-CAT-ISU-033, SECM-CAT-ISU-040, SECM-CAT-IAA-013, SECM-CAT-IPC-004.

- Evidence anchor (from workbook description): The application shall remove out-of-date components after update installation, disable the use of unsupported components, and be decommissioned when there is no maintenance or vendor support available.
- Evidence anchor (from workbook description): The application shall implement procedures to notify the user upon the application being deprecated.

7. Recommendations

Recommendations are organized by the same weakness patterns presented in the Main deficiencies section. They target remediation of workbook-evidenced gaps and may include strengthening controls to improve security posture.

Hardcoded credentials / embedded secrets

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Authorization / RBAC / least privilege gaps

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Insecure local storage / key management gaps

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Weak authentication lifecycle / brute-force protections

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Supply chain governance & outdated components

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.

- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Transport security / certificate validation weaknesses

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Input validation & injection weaknesses (XSS/SQLi/command/log injection)

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Audit logging completeness / retention / alerting gaps

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Tampering / reverse engineering protections missing

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.
- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

Privacy notice / consent / governance gaps

- Define and document secure-by-default requirements for this control area, and implement automated tests to prevent regressions.

- Apply least-privilege, defense-in-depth, and secure configuration baselines aligned with mHealth/EMR risk profiles.
- Introduce step-up authentication, such as MFA, TOTP, FIDO2, or Android BiometricPrompt, for sensitive actions where feasible.
- Validate effectiveness through security testing and re-assessment of the mapped non-compliant controls.

8. Visual Analytics

Figures below summarize workbook-derived outcomes and distributions. All figures: source: audit workbook.

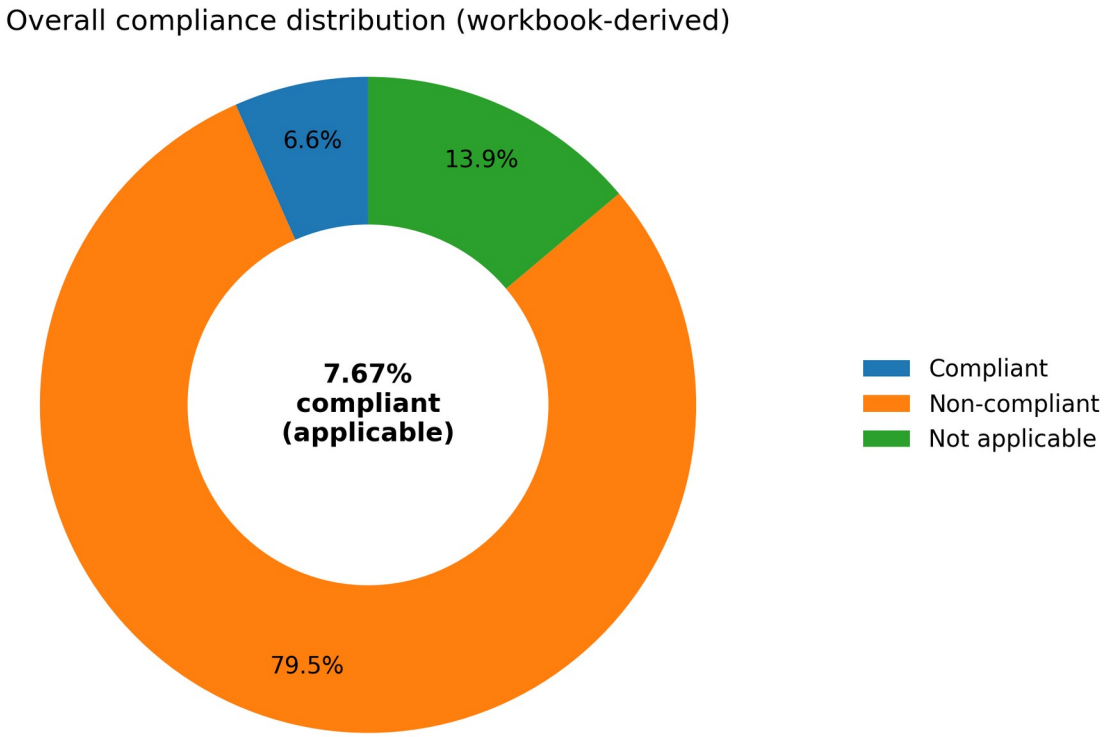
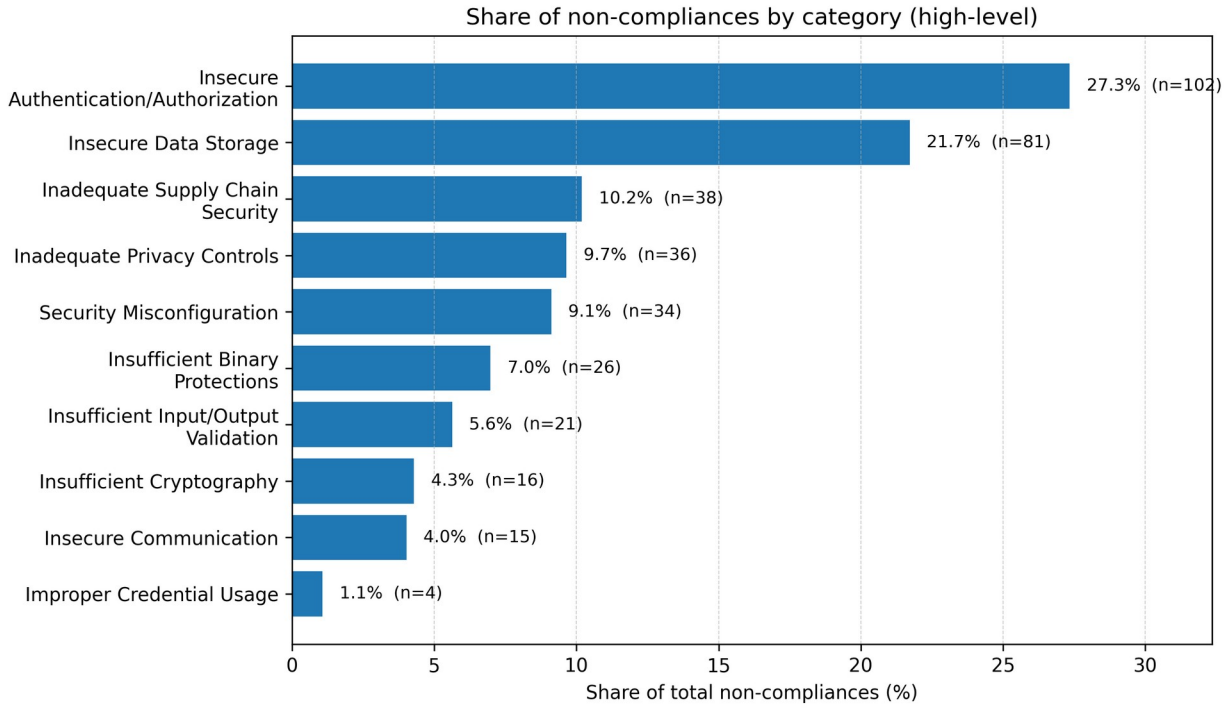
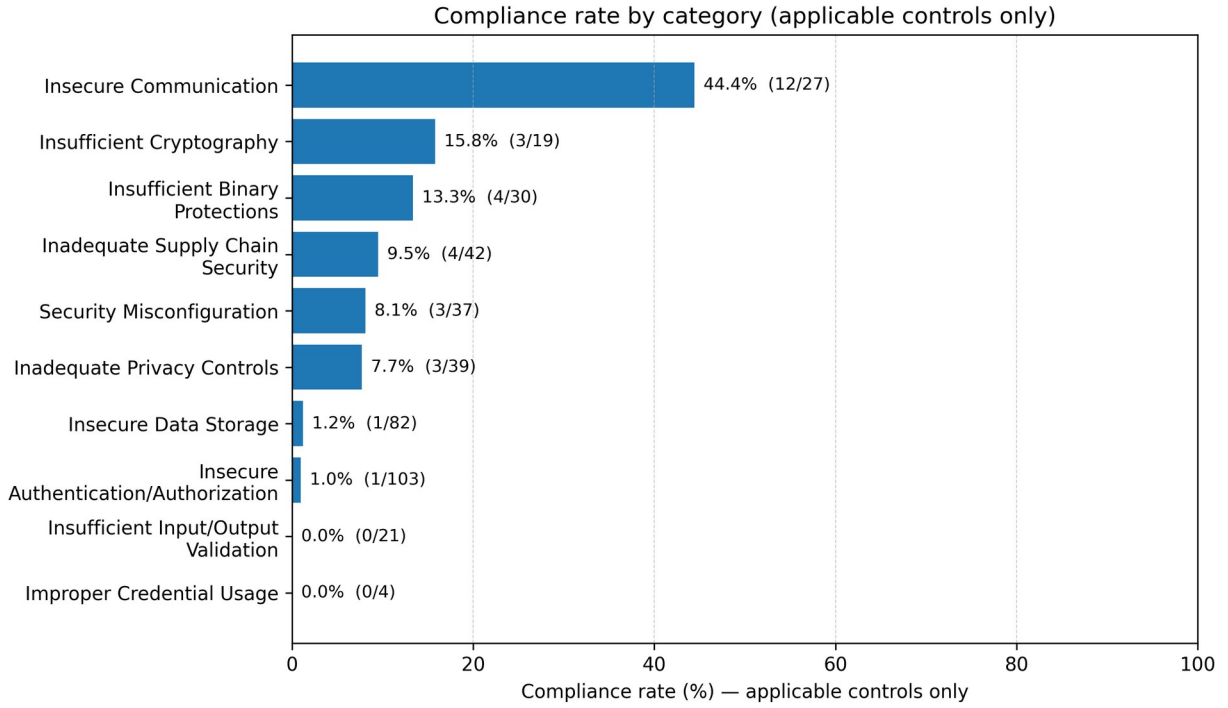


Figure 1. Overall compliance distribution (donut chart; source: audit workbook).



Source: audit workbook. Total non-compliances: 373.

Figure 2. Share of non-compliances by category (legible horizontal bars; source: audit workbook).



Note: (c/a) indicates Compliant / Applicable controls per category. Source: audit workbook.

Figure 3. Compliance rate by category (applicable controls only; source: audit workbook).

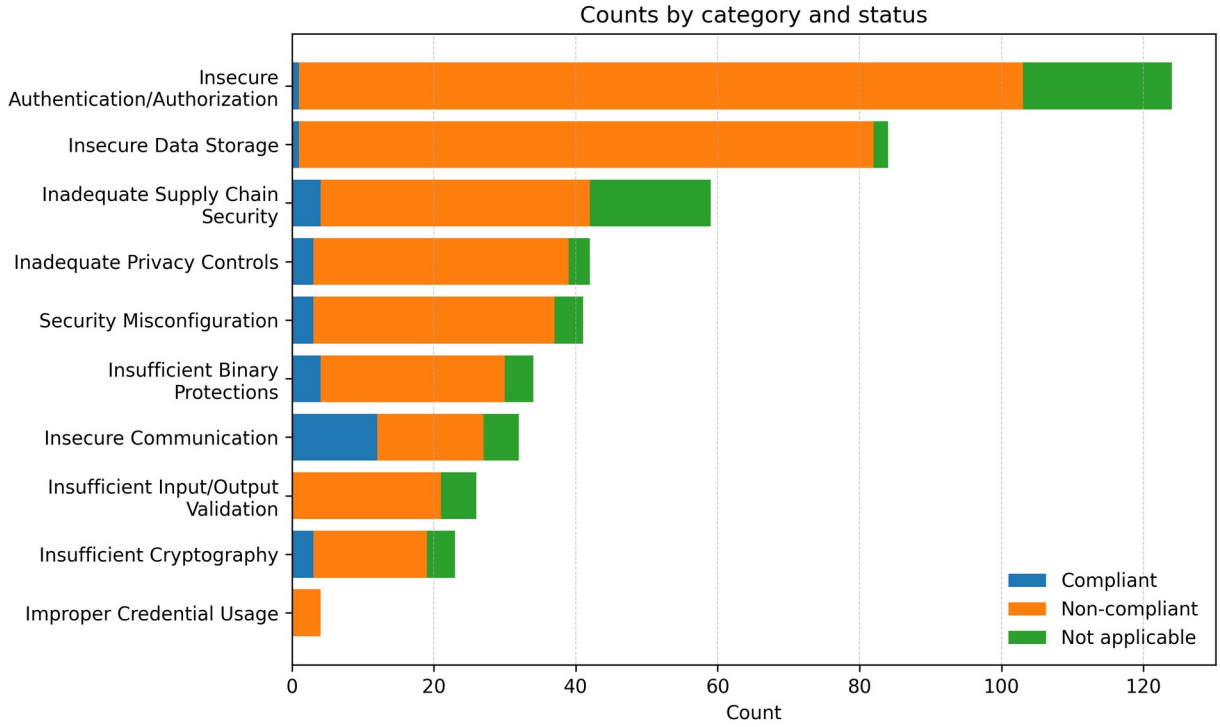


Figure 4. Counts by category and status (horizontal stacked bars; source: audit workbook).

9. Management Action Plan (MAP)

Severity and likelihood nomenclature follow the rubric in Section 5.3. Likelihood is supported by workbook prevalence counts recorded in the Workbook basis column.

Finding / weakness pattern	Severity	Likelihood	Workbook basis	Owner	Management action	Target window	Target date	Acceptance criteria / KPI
Hardcoded credentials / embedded secrets	High	High	65 mapped non-compliant control(s) in workbook.	Mobile Engineering / Security Engineering	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–90 days	16 Jul 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Authorization / RBAC / least privilege gaps	High	High	50 mapped non-compliant control(s) in workbook.	Mobile Engineering / Governance	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–90 days	16 Jul 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Insecure local storage / key management gaps	High	Medium–High	49 mapped non-compliant control(s) in workbook.	Mobile Engineering	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–90 days	16 Jul 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Weak authentication	High	Medium–High	44 mapped non-	Mobile Engineering	Implement remediati	0–90 days	16 Jul 2026	Evidence recorded (tests/co

lifecycle / brute-force protections			compliant control(s) in workbook.		on actions aligned to the weakness pattern and validate effectiveness.			nfigs/release refs); mapped controls can be re-tested and re-scored as compliant.
Supply chain governance & outdated components	High	Medium–High	20 mapped non-compliant control(s) in workbook.	DevOps / Security Engineering	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–90 days	16 Jul 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Transport security / certificate validation weaknesses	High	Medium–High	20 mapped non-compliant control(s) in workbook.	Mobile Engineering / DevOps	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–90 days	16 Jul 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Input validation & injection weaknesses (XSS/SQLi/command/log injection)	High	Medium	10 mapped non-compliant control(s) in workbook.	Mobile Engineering	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–90 days	16 Jul 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Audit	Medium	Medium–	47	Governa	Impleme	0–180	14 Oct	Evidence

logging completeness / retention / alerting gaps		High	mapped non-compliant control(s) in workbook.	nce / DevOps	nt remediation actions aligned to the weakness pattern and validate effectiveness.	days	2026	recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Tampering / reverse engineering protections missing	Medium	Medium	16 mapped non-compliant control(s) in workbook.	Mobile Engineering	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–180 days	14 Oct 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.
Privacy notice / consent / governance gaps	Medium	Low–Medium	6 mapped non-compliant control(s) in workbook.	Governance / Product	Implement remediation actions aligned to the weakness pattern and validate effectiveness.	0–180 days	14 Oct 2026	Evidence recorded (tests/configs/release refs); mapped controls can be re-tested and re-scored as compliant.

Appendix A - Traceability index (non-exhaustive)

For complete traceability and evidence, refer to the audit workbook.

- Hardcoded credentials / embedded secrets: SECM-CAT-ICU-001, SECM-CAT-ICU-002, SECM-CAT-ICU-003, SECM-CAT-ICU-004, SECM-CAT-ISU-001
- Authorization / RBAC / least privilege gaps: SECM-CAT-ISU-027, SECM-CAT-ISU-032, SECM-CAT-IAA-005, SECM-CAT-IAA-006, SECM-CAT-IAA-025
- Insecure local storage / key management gaps: SECM-CAT-ISU-019, SECM-CAT-ISU-036, SECM-CAT-IAA-040, SECM-CAT-IAA-112, SECM-CAT-IOV-020
- Weak authentication lifecycle / brute-force protections: SECM-CAT-ISU-011, SECM-CAT-IAA-003, SECM-CAT-IAA-008, SECM-CAT-IAA-011, SECM-CAT-IAA-017
- Supply chain governance & outdated components: SECM-CAT-ISU-008, SECM-CAT-ISU-009, SECM-CAT-ISU-013, SECM-CAT-ISU-022, SECM-CAT-ISU-023
- Transport security / certificate validation weaknesses: SECM-CAT-ISU-003, SECM-CAT-ISU-004, SECM-CAT-ISU-007, SECM-CAT-ISU-010, SECM-CAT-ISU-018
- Input validation & injection weaknesses (XSS/SQLi/command/log injection): SECM-CAT-ISU-037, SECM-CAT-IOV-001, SECM-CAT-IOV-004, SECM-CAT-IOV-011, SECM-CAT-IOV-015
- Audit logging completeness / retention / alerting gaps: SECM-CAT-IAA-004, SECM-CAT-IAA-010, SECM-CAT-IAA-014, SECM-CAT-IAA-019, SECM-CAT-IAA-021
- Tampering / reverse engineering protections missing: SECM-CAT-ISU-006, SECM-CAT-ISU-012, SECM-CAT-ISU-017, SECM-CAT-ISU-026, SECM-CAT-ISU-039
- Privacy notice / consent / governance gaps: SECM-CAT-ISU-033, SECM-CAT-ISU-040, SECM-CAT-IAA-013, SECM-CAT-IPC-004, SECM-CAT-IPC-010

Appendix B - Positive controls verification (workbook traceability)

This appendix verifies each Positive controls observed statement by providing the originating PUID, flags used, and an evidence excerpt when available.

Positive control statement (as reported)	Workbook PUID	Flags used	Evidence / justification (excerpt)
The application applications not change the SSL verification method that can allow self-signed certificates. Self-signed certificates or a local Certificate Authority (CA) be used during development to keep with good SSL practices.	SECM-CAT-ISU-002	has_android_ssl_pinning_present, has_android_ssl_pinning_detected, has_manifest_allow_clear_text_traffic_true	Result: yes for requirement SECM-CAT-ISU-002. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application remove all code that seems to accept every SSL/TLS certificate, e.g., org.apache.http.conn.ssl.AllowAllHostnameVerifier, SSLSocketFactory.ALLOW_ALL_HOSTNAME_VERIFIER, post-development cycle for secure certificate validation.	SECM-CAT-ISU-005	has_android_ssl_pinning_present, has_android_ssl_pinning_detected, has_manifest_allow_clear_text_traffic_true	Result: yes for requirement SECM-CAT-ISU-005. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application be free of adware and known malware (via virus-checking against some established library of viruses), and prevents the execution of malicious code, as well as disallowing the uploading of malicious or dangerous-looking scripts or files.	SECM-CAT-ISU-035	has_malware_detections	Result: yes for requirement SECM-CAT-ISU-035. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application request the READ_SMS permission only when absolutely necessary, minimize its usage, and securely handle SMS data to prevent misuse or exploitation by	SECM-CAT-ISU-056	has_android_extra_risky_permissions_present, has_supports_runtime_permission_management	Result: yes for requirement SECM-CAT-ISU-056. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated

malicious third parties.			signals support ...
The application encrypt passwords during transmission to ensure that no passwords are sent in clear text over the network.	SECM-CAT-IAA-009	has_manifest_allow_clear_text_traffic_true, has_android_ssl_pinning_present, has_ssl_pinning_findings_severity_good	Result: yes for requirement SECM-CAT-IAA-009. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application prioritize secure and authenticated communication methods, such as Firebase Cloud Messaging (FCM) or encrypted IP-based networking protocols, instead of relying on SMS for app-server interactions.	SECM-CAT-ICO-004	has_tls_ssl_pinning_implemented, has_ssl_cert_pinning_implemented	Result: yes for requirement SECM-CAT-ICO-004. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application assume that the network layer is unsecure and susceptible to eavesdropping. Implement end-to-end encryption and other secure communication practices to safeguard sensitive data transmitted over the network.	SECM-CAT-ICO-006	has_tls_ssl_pinning_implemented, has_android_ssl_pinning_detected, has_insecure_http_based_webview_communication	Result: yes for requirement SECM-CAT-ICO-006. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...